MedBridge Health, Inc.

Incident Response Policy

1. Purpose

The purpose of this policy is to establish how MedBridge Health identifies, reports, investigates, and responds to cybersecurity incidents that could affect company systems, patient information, or business operations.

Since MedBridge Health provides telehealth services and handles Protected Health Information (PHI), responding to security incidents quickly is important for protecting patient privacy and keeping healthcare services available.

This policy explains the steps employees and the incident response team must follow when a potential security incident occurs. It also outlines how incidents are classified, who is responsible for managing the response, and when an incident may need to be reported under HIPAA.

Having a documented incident response process will help MedBridge Health handle security threats more consistently, reduce potential damage, and improve its ability to recover from cybersecurity incidents.

---

2. Scope

This policy applies to all MedBridge Health employees, contractors, temporary workers, and authorized third-party personnel who use or have access to company systems, networks, applications, or sensitive information.

It covers employees working at the San Francisco office and those working remotely. Anyone who discovers or suspects a security incident involving company resources must follow the reporting requirements outlined in this policy.

The policy covers the following:

- **Cloud Infrastructure:** Amazon Web Services (AWS), including EC2 instances, RDS databases, S3 storage, and related services.
- **Healthcare Applications:** Patient applications, clinician portals, and Electronic Health Records (EHR) systems.
- **Identity and Access Management:** Okta, employee accounts, administrative accounts, and MFA systems.
- **Company Devices:** Employee laptops, workstations, and other authorized devices.
- **Networks:** The San Francisco office network, firewalls, Wi-Fi, and approved remote connections.
- **Third-Party Services:** Google Workspace, Zoom for Healthcare, Twilio, Zendesk, and other vendors supporting company operations.
- **Sensitive Information:** PHI, Personally Identifiable Information (PII), employee records, financial information, and confidential company data.

This policy applies to suspected and confirmed cybersecurity incidents, including phishing attacks, malware infections, ransomware, unauthorized access, data breaches, and service disruptions caused by security threats.

All exceptions must follow the approval process outlined in Section 5.

---

3. Roles and Responsibilities

Responding to cybersecurity incidents requires cooperation between MedBridge Health's leadership, technical staff, and employees.

Since the company does not have a dedicated cybersecurity department, the part-time virtual Chief Information Security Officer (vCISO), IT Manager, CTO, and Privacy Officer share responsibility for coordinating incident response activities.

3.1 Incident Response Roles and Responsibilities

Role	Responsibilities
Chief Executive Officer (CEO)	Provides executive oversight, approves major business decisions during incidents, and authorizes high-impact response actions when needed.

Role	Responsibilities
Chief Technology Officer (CTO)	Oversees technical investigations, containment, system recovery, and incidents involving AWS or healthcare applications.
Virtual Chief Information Security Officer (vCISO)	Coordinates the incident response process, assigns incident severity levels, documents findings, and oversees response activities.
IT Manager	Investigates suspicious activity, reviews security alerts, isolates affected devices, manages accounts, and supports system recovery.
Privacy Officer (COO)	Reviews incidents involving PHI, coordinates HIPAA breach assessments, and manages required breach notifications with legal guidance.
HR Manager	Assists with incidents involving employees, coordinates employee communications when needed, and maintains relevant training records.
Employees and Contractors	Report suspicious activity immediately, follow incident response instructions, and avoid interfering with investigations.

3.2 Incident Response Coordination

The vCISO will act as the incident response coordinator and work with the appropriate department leaders to manage security incidents.

The IT Manager and CTO will handle technical response activities, including investigating alerts, securing affected systems, and restoring operations.

The Privacy Officer must be involved whenever an incident could involve patient information or create HIPAA reporting obligations.

The CEO must be informed of high and critical severity incidents that could significantly affect company operations, patient information, or business relationships.

3.3 External Support

Depending on the incident, MedBridge Health may need help from external security specialists, legal counsel, its cyber insurance provider, cloud vendors, or law enforcement.

The vCISO and CEO will coordinate outside assistance when necessary.

The Privacy Officer and legal counsel will review external communications involving patient information or regulatory obligations.

---

4. Policy Statements

MedBridge Health must maintain a documented incident response process for identifying, investigating, containing, and recovering from cybersecurity incidents.

All employees and authorized personnel must follow the requirements outlined in this section.

4.1 Incident Identification and Reporting

1. Employees must report suspected cybersecurity incidents to the IT Manager or vCISO immediately after discovery.
2. Reportable incidents include suspected phishing, malware infections, unauthorized access, lost devices, suspicious account activity, and possible patient information exposure.
3. Employees must not attempt to investigate or resolve serious incidents on their own unless specifically authorized.
4. The IT Manager must record reported incidents in an incident tracking system or incident log.
5. Each reported incident must include the date and time of discovery, affected systems, initial description, and person responsible for reviewing the incident.
6. High-priority security alerts from critical systems must be reviewed at least once every business day.

4.2 Incident Severity Classification

MedBridge Health will use four severity levels to determine how urgently an incident needs to be investigated and addressed.

Severity	Classification	Description	Example
Sev 1	**Critical**	A major security incident that significantly affects patient information, critical systems, or healthcare services.	Confirmed ransomware affecting production systems or widespread PHI exposure.

Severity	Classification	Description	Example
Sev 2	**High**	A serious incident that may involve sensitive information or disrupt important business systems.	Confirmed unauthorized access to an employee account with PHI access.
Sev 3	**Medium**	A security incident with limited impact that requires investigation and corrective action.	Malware detected and contained on one employee laptop.
Sev 4	**Low**	A minor security event with little or no confirmed business impact.	A reported phishing email that was blocked before an employee interacted with it.

The vCISO must assign an initial severity level based on the available information.

Incident severity may change as the investigation continues and new information becomes available.

4.3 Incident Escalation and Response Times

1. **Sev 1 — Critical:** The IT Manager or vCISO must be contacted immediately. The initial response must begin within 30 minutes of the incident being reported.
2. **Sev 2 — High:** The incident must be escalated to the vCISO and appropriate technical staff immediately. The initial response must begin within one hour.
3. **Sev 3 — Medium:** The incident must be reviewed within four business hours.
4. **Sev 4 — Low:** The incident must be reviewed within two business days.
5. The CEO must be notified of Sev 1 incidents as soon as the initial severity is confirmed.
6. The Privacy Officer must be notified immediately whenever an incident may involve PHI.

These response times are internal targets established for MedBridge Health's proposed incident response process.

4.4 Incident Investigation and Analysis

1. The IT Manager, CTO, or designated technical staff must investigate reported security incidents.
2. Investigations must identify affected systems, potentially exposed information, suspicious activity, and the possible cause of the incident.
3. Available evidence, including relevant logs, alerts, and system information, must be collected and documented.
4. Evidence must be protected from unauthorized access or modification.

5. Important investigation activities must be recorded, including timestamps, actions taken, and personnel involved.
6. The vCISO must review findings and determine whether additional investigation or escalation is necessary.

4.5 Incident Containment

1. Affected systems must be isolated when necessary to prevent an incident from spreading.
2. Compromised accounts must be disabled, secured, or have their access restricted when appropriate.
3. Malicious network connections must be blocked when necessary to protect company systems.
4. The CTO must coordinate major containment actions that could interrupt healthcare services.
5. Evidence should be preserved before changes are made whenever doing so will not create unacceptable security or patient safety risks.
6. Containment activities must be documented in the incident record.

4.6 Threat Removal and System Recovery

1. Identified malicious software, unauthorized access methods, and other confirmed threats must be removed or addressed before affected systems return to normal operation.
2. Compromised credentials must be reset or otherwise secured.
3. Affected systems must be reviewed for vulnerabilities or misconfigurations that may have contributed to the incident.
4. Systems must be restored using trusted backups or other approved recovery methods when necessary.
5. The CTO and IT Manager must verify that restored systems are functioning properly before returning them to production.
6. Additional monitoring must be performed after recovery to identify possible recurring suspicious activity.
7. Recovery actions and any remaining risks must be documented.

4.7 PHI Breach Assessment and Notification

1. Any suspected unauthorized access, use, or disclosure of PHI must be reported to the Privacy Officer immediately.
2. The Privacy Officer, with legal guidance when needed, must determine whether the incident qualifies as a reportable breach under applicable HIPAA requirements.
3. The breach assessment must consider the nature of the information involved, the individuals who accessed or received it, whether it was actually acquired or viewed, and the extent to which the risk was reduced.

4. Required notifications to affected individuals must be provided without unreasonable delay and no later than 60 calendar days after discovery of a reportable breach, subject to applicable legal exceptions.
5. For breaches affecting 500 or more individuals, MedBridge Health must notify the U.S. Department of Health and Human Services (HHS) without unreasonable delay and no later than 60 calendar days after discovery.
6. For breaches affecting fewer than 500 individuals, notification to HHS may be submitted annually but must be completed within 60 days after the end of the calendar year in which the breach was discovered.
7. When a breach affects more than 500 residents of a state or jurisdiction, the Privacy Officer must coordinate notification to the appropriate media outlets when required.
8. The Privacy Officer must maintain records of breach assessments, required notifications, and decisions explaining why notification was or was not necessary.
9. Additional state-specific or contractual notification requirements must also be reviewed.

A cybersecurity incident does not automatically mean a reportable HIPAA breach has occurred. The Privacy Officer must document the required assessment before making that determination.

4.8 Incident Communication and Documentation

1. The vCISO must maintain an incident record documenting important findings, response actions, decisions, and communications.
2. Employees must not publicly share details about security incidents unless authorized.
3. External incident communications must be reviewed by the appropriate leadership and legal or privacy personnel.
4. The CEO must be informed of major incidents that could affect patient services, company finances, or business partners.
5. The Privacy Officer must coordinate communications involving affected patients and required regulatory notifications.
6. Third-party vendors must be contacted when their services or systems are involved in an incident.
7. Incident records and investigation evidence must be stored securely and retained according to applicable requirements.

4.9 Post-Incident Review and Improvements

1. MedBridge Health must complete a documented post-incident review for all Sev 1 and Sev 2 incidents within 10 business days after incident closure.
2. The review must identify what happened, how the incident was detected, what actions were taken, and what could be improved.
3. Any identified security weaknesses must be assigned to an appropriate risk or remediation owner.
4. Corrective actions must have documented target dates and completion statuses.
5. The vCISO must review the incident response process at least once every 12 months.

6. MedBridge Health must conduct at least one incident response tabletop exercise annually.
7. Lessons learned from incidents and exercises must be used to improve security policies, employee training, and technical controls.

---

5. Exceptions

MedBridge Health understands that certain technical limitations or business situations may require temporary exceptions to specific incident response requirements.

Exceptions must be reviewed and approved before personnel are allowed to operate outside the policy.

Exceptions cannot override legal or regulatory obligations, including required breach notifications.

5.1 Exception Request Process

1. Employees or department managers must submit a documented request explaining which requirement cannot be followed and why.
2. The request must identify the affected systems, business processes, or information and describe the potential risks.
3. The vCISO must assess the risks and recommend additional safeguards when necessary.
4. The appropriate system owner must review the business need for the exception.
5. The CEO must approve exceptions involving high or critical risks. Lower-risk exceptions may be approved by the vCISO.
6. Approved exceptions must be documented in the company's exception register with an expiration date.

5.2 Exception Monitoring and Review

The vCISO must review approved exceptions at least every 90 days to make sure the risks are still understood and the required security measures remain in place.

Exceptions must be reviewed before they expire. When an exception is no longer needed, the affected system or process must return to following the original policy requirement.

Any exception involving PHI must also be reviewed by the Privacy Officer.

---

6. Enforcement

All MedBridge Health employees, contractors, and authorized third-party personnel must follow the incident reporting and response requirements outlined in this policy.

Failing to report an incident, interfering with an investigation, or ignoring incident response instructions could increase security risks and affect the company's ability to protect patient information.

MedBridge Health will review policy violations and determine appropriate corrective actions based on the seriousness of the situation.

Depending on the violation, corrective actions may include:

- **Additional Security Training:** Employees may be required to complete additional training on recognizing and reporting cybersecurity incidents.
- **Written Warning:** Employees may receive a formal warning for failing to follow incident response requirements.
- **Access Restrictions:** Access to certain company systems may be temporarily restricted or removed.
- **Disciplinary Action:** Serious or repeated violations may result in further disciplinary action, including termination of employment.
- **Contractual Action:** Contractors or vendors who violate applicable requirements may face consequences under their agreements with MedBridge Health.

The HR Manager will work with department leaders when employee disciplinary action is necessary.

The vCISO and IT Manager will review security-related violations, while the Privacy Officer must be involved when patient information may have been affected.

MedBridge Health will handle violations consistently and consider the incident's impact and whether the violation was intentional or accidental.

---

7. Related Policies and References

MedBridge Health's Incident Response Policy uses cybersecurity guidance and healthcare regulations to establish requirements for managing security incidents and responding to potential data breaches.

These references help keep the policy consistent with the company's other security requirements.

7.1 Related Security Policies

- **Information Security Policy:** Establishes the company's overall security requirements, responsibilities, and risk management expectations.
- **Acceptable Use Policy:** Explains how employees and contractors must use company systems and report suspicious activity.
- **Password and Authentication Policy:** Establishes authentication requirements and procedures for protecting accounts from unauthorized access.

7.2 Regulations, Frameworks, and Standards

Reference	Purpose
HIPAA Security Rule (45 CFR Part 164, Subpart C)	Establishes administrative, physical, and technical security requirements for protecting electronic PHI.
HIPAA Breach Notification Rule (45 CFR §§ 164.400–414)	Establishes requirements for assessing and reporting breaches of unsecured PHI.
HITECH Act	Supports healthcare information security and breach notification requirements.
NIST SP 800-61 Revision 3 (2025)	Provides guidance for integrating incident response into cybersecurity risk management.
NIST Cybersecurity Framework (CSF) 2.0	Provides guidance for identifying, protecting against, detecting, responding to, and recovering from cybersecurity risks, including governance activities.
ISO/IEC 27001:2022	Provides requirements for establishing and managing an information security management system.

7.3 Policy Review and Updates

The vCISO must review this policy at least once every 12 months or whenever major changes occur that could affect MedBridge Health's incident response requirements.

The policy must also be reviewed after major security incidents, significant changes to company systems, or updates to applicable regulations.

Any major changes must be approved by the CEO before the updated policy takes effect.

Employees and contractors must be informed of updates that affect their incident reporting or response responsibilities.

8. Definitions

This section explains important cybersecurity and compliance terms used throughout MedBridge Health's Incident Response Policy.

Term	Definition
Security Incident	An event that compromises or threatens the confidentiality, integrity, or availability of company systems or information.
Incident Response	The process of identifying, investigating, containing, and recovering from cybersecurity incidents.
Incident Severity	A classification used to determine how serious an incident is and how urgently it needs to be addressed.
Containment	Actions taken to limit the impact of a security incident and prevent it from spreading.
Eradication	The process of removing identified threats or malicious activity from affected systems.
Recovery	The process of restoring affected systems and services to normal operations.
Protected Health Information (PHI)	Patient health information that can identify an individual and is protected under HIPAA.
Electronic Protected Health Information (ePHI)	PHI that is created, stored, received, or transmitted electronically.
Data Breach	An incident involving unauthorized access, use, or disclosure of protected or sensitive information.
Business Associate Agreement (BAA)	A contract required under HIPAA for certain vendors that handle PHI on behalf of a covered entity or business associate.
Incident Response Team	The employees and authorized personnel responsible for coordinating and managing security incidents.

Term	Definition
Tabletop Exercise	A simulated incident used to practice incident response procedures and identify areas for improvement.
Chain of Custody	Documentation showing who collected, handled, transferred, or accessed evidence during an investigation.
Post-Incident Review	A review completed after an incident to identify lessons learned and improvements.
Virtual Chief Information Security Officer (vCISO)	An external security professional who helps manage an organization's cybersecurity program.
Policy Exception	A formally approved, temporary allowance to operate outside a specific policy requirement.

---

9. Document Control

This section documents the ownership, approval, and review requirements for MedBridge Health's Incident Response Policy.

The vCISO is responsible for maintaining the policy and coordinating incident response activities. The CEO is responsible for approving the policy before it officially takes effect.

9.1 Policy Information

Field	Details
Policy Title	Incident Response Policy
Organization	MedBridge Health, Inc.
Policy ID	MBH-IRP-004
Version	1.0
Policy Owner	Virtual Chief Information Security Officer (vCISO)
Policy Approver	Chief Executive Officer (CEO)
Effective Date	Pending Approval

Field	Details
Last Review Date	Not Yet Reviewed
Next Review Date	12 months after approval
Review Frequency	Annually and after major incidents
Policy Status	Draft — Pending Approval

9.2 Policy Review and Approval

The vCISO must review this policy at least once every 12 months and after major cybersecurity incidents that identify weaknesses in the company's response process.

Any changes must be documented and submitted to the CEO for approval before the updated policy takes effect.

Employees and contractors must be informed of any changes that affect their incident reporting or response responsibilities.

9.3 Version History

Version	Date	Description	Updated By
1.0	November 2, 2026	Initial draft of the Incident Response Policy	vCISO (Simulated)

9.4 Document Disclaimer

This Incident Response Policy was created for MedBridge Health, Inc., a fictional healthcare company, as part of my hands-on GRC lab. All security requirements, response procedures, responsibilities, and approval processes are simulated and do not represent an officially implemented security program.